



General Sir John Kotelawala Defence University, Sri Lanka .

Faculty of Technology

Department of Biosystems Technology

PROFESSIONAL ETHICS IN IT

Responsibility and Rights

Individual Assessment

Student Name : M. Yuwani Anuththara

Service/Index Number : D/ICT/25/0121

Instructed by : Ms K . Anuradha

Stream/Intake : Intake 42

Module Code/ Name : Professional Ethics

Date of submission : 13.02.202

Part A – Ethical Framework

Question 1 – Respect for Authority in IT Organization

(a) Explain what went wrong in this scenario.

Four Major Mistakes:

1. Bypassing the Change Management Process:

The engineer implemented a live system change without following the organization's approval and testing procedures. In IT operations, all fixes especially those affecting production must go through change control to ensure stability and accountability.

2. Failure to Conduct Risk Assessment or Impact Analysis:

The engineer didn't evaluate the potential downstream effects of their fix. Even well-intentioned security updates can disrupt system functions or dependencies.

3. Lack of Communication and Escalation:

The engineer failed to notify supervisors, senior engineers, or the security team about the vulnerability and proposed actions. This broke the chain of authority and coordination.

4. Poor Documentation and Incident Tracking:

The engineer didn't document the vulnerability or the fix, preventing post-incident review, traceability, or rollback. This made diagnosis of the subsequent system failure more difficult.

(b) the difference between 'respecting authority' and 'blind obedience'

Respecting authority means following organizational rules, policies, and management structures while still using professional judgment and ethical responsibility. It involves communicating with supervisors, following proper procedures, and ensuring decisions align with company standards and risk management practices.

Blind obedience, on the other hand, means following instructions or acting without questioning consequences, professional responsibility, or organizational processes. It ignores critical thinking and can lead to serious mistakes because the individual does not evaluate risks or consult relevant authorities.

In the given scenario, the junior engineer attempted to solve a serious security problem immediately without informing supervisors or following approval procedures. This shows a lack of respect for authority because organizational security policies and change management procedures are designed to prevent unexpected system failures. The engineer did not communicate with senior staff or conduct proper testing before implementing the fix.

However, the engineer also demonstrated a form of blind decision-making by assuming that acting quickly was the best solution without evaluating the wider impact on the system. Although the intention was to solve a security issue, failing to follow established processes caused system malfunction and negatively affected customers.

This scenario highlights that respecting authority does not mean ignoring problems or delaying action unnecessarily. Instead, professionals should report urgent issues through proper escalation channels while ensuring that solutions are approved, documented, and tested. Blind obedience or acting independently without considering organizational policies can both create serious technical and ethical consequences.

(c)Real-world cases where IT professionals faced consequences for either

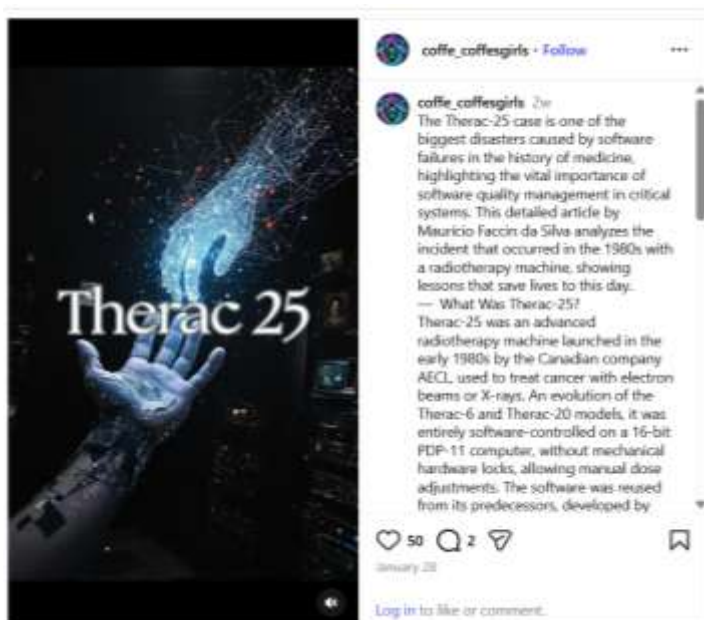
Case 1: Therac-25 Radiation Machine Incidents (1985–1987)

Company: Atomic Energy of Canada Limited (AECL)

System: Therac-25 Radiation

Therapy Machine

Period: 1985 – 1987



➤ [Radiation Machine Incident](#)

Background

The Therac-25 was a computerized radiation therapy machine used in hospitals to treat cancer patients. It was designed to deliver precise doses of radiation to destroy cancer cells while minimizing damage to healthy tissues. The system relied heavily on software control rather than hardware safety mechanism which made it more efficient but also increased dependence on correct programming and testing.

Issue

Serious software design and testing failures existed in the Therac-25 system. Software engineers reused code from older radiation machines but removed several hardware safety controls because they believed the software alone was reliable. Management and developers assumed that previous system experience guaranteed safety and therefore reduced independent testing and verification processes.

Several engineers followed internal directives and trusted existing design decisions without thoroughly challenging safety risks. Additionally:

- The system lacked proper fail-safe mechanisms.
- Error messages shown to operators were unclear and misleading.
- Testing procedures were insufficient for real-world operating conditions.
- Reports from hospitals about malfunctioning equipment were not immediately escalated or properly investigated.

Outcome

Between 1985 and 1987, at least **six patients** received massive radiation overdoses due to software errors. These overdoses caused severe injuries and several deaths. Investigations revealed that small software race-condition bugs allowed radiation beams to be delivered at extremely high intensities.

The incident resulted in:

- Major recalls and redesign of the Therac-25 system.
- Severe criticism of AECL's software engineering practices.
- Global recognition of the importance of safety testing in medical software.
- Development of stricter software safety standards in healthcare technology.

Ethical Lesson

This case demonstrates that respecting authority does not mean blindly trusting design decisions or management assumptions. Engineers have a professional duty to question unsafe processes and escalate potential risks. The Therac-25 incident showed that blind obedience to system design and inadequate testing can directly endanger human life.

Case 2: Edward Snowden and NSA Surveillance Disclosures (2013)

Organization: National Security Agency (NSA)

Individual: Edward Snowden

Year: 2013

Background

Edward Snowden was a contractor working for the NSA, responsible for managing and maintaining classified government surveillance systems. During his work, Snowden gained access to information about secret global surveillance programs conducted by intelligence agencies.

Issue

Snowden discovered that intelligence agencies were collecting massive amounts of data from global communications, including phone calls, emails, and internet activity of millions of citizens. He believed these surveillance programs violated privacy rights and were conducted without sufficient public awareness or legal transparency.

Instead of reporting the issue through internal government channels, Snowden chose to leak classified documents to journalists. He argued that internal reporting mechanisms would not stop the surveillance and could put him at risk without creating meaningful public change.

Outcome

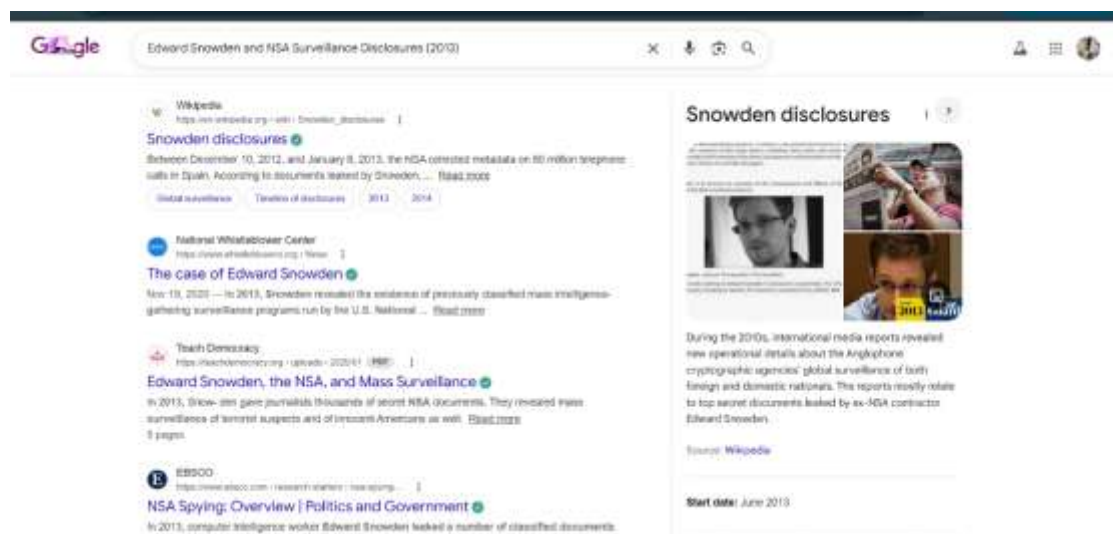
Snowden leaked thousands of classified documents in 2013. The disclosures revealed extensive global surveillance programs and triggered worldwide discussions about government privacy violations.

The consequences included:

- Snowden lost his job and security clearance.
- He faced criminal charges under United States espionage laws.
- Snowden left the United States and sought asylum abroad.
- The leaks sparked global public debates about digital privacy and government surveillance.
- Several countries introduced stronger privacy regulations and surveillance oversight reforms.

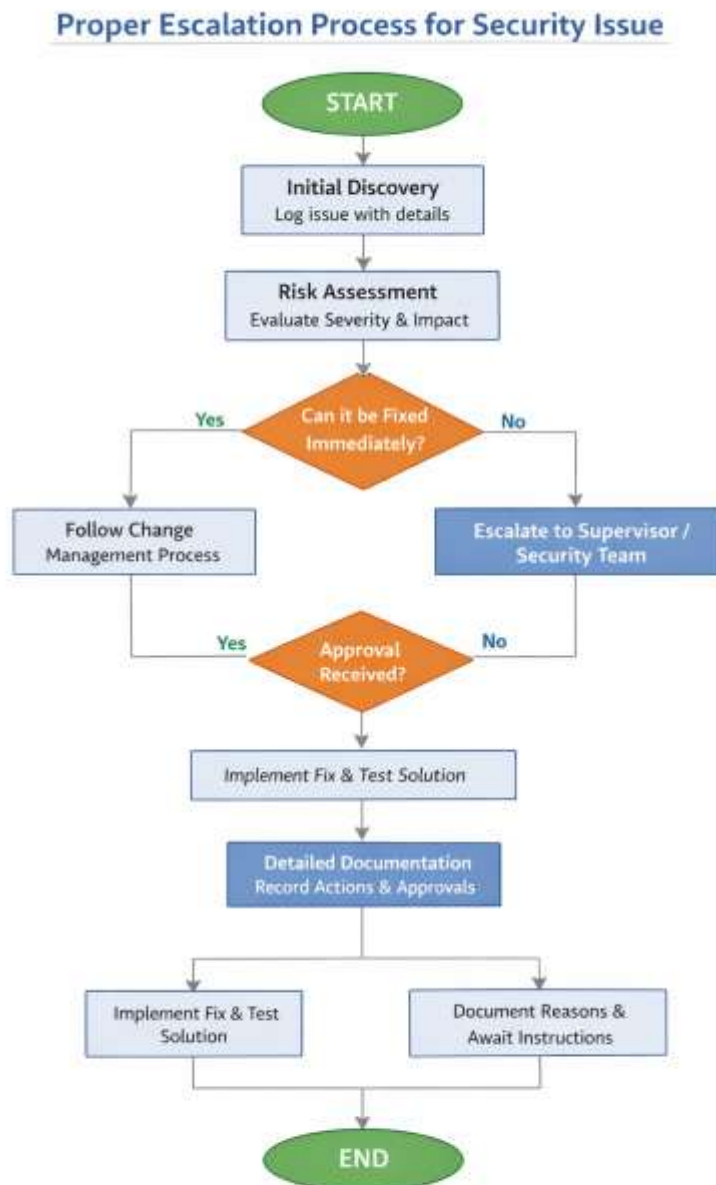
Ethical Lesson

This case highlights the complex ethical dilemma between organizational loyalty and responsibility to society. Snowden disobeyed authority to expose practices he believed were harmful to public rights. Although his actions led to legal punishment and personal consequences, they also influenced global policy discussions about privacy and government accountability.



➡ [The Case of Edward Snowden](#)

(d) flowchart showing the proper escalation process



Question 2: Confidentiality and Data Protection in Sri Lanka – Equifax Data Breach (2017)

(e) Equifax Breach Detail

➡ [Data Protection](#)



Technical Vulnerability:

- The breach occurred due to a vulnerability in Apache Struts web application framework (CVE-2017-5638).
- Attackers exploited this vulnerability to gain unauthorized access to sensitive customer records, including Social Security numbers, dates of birth, addresses, and in some cases, credit card numbers.
- Equifax had failed to patch the known vulnerability in a timely manner, despite Apache issuing a security update.

Timeline:

- Vulnerability was identified and publicly reported in March 2017.
- Breach activity occurred mid-May to July 2017.
- Equifax publicly disclosed the breach on September 7, 2017.

Consequences:

- Data of 147.9 million Americans, 15.2 million British citizens, and 19,000 Canadian citizens were exposed.
- CEO and executives faced intense public scrutiny; several resigned.
- Equifax faced fines exceeding \$700 million in settlements with U.S. regulators.
- Reputation damage was severe, with long-term trust issues among customers.

Sources for Evidence:

- Official Equifax press releases - <https://investor.equifax.com/news-events/press-releases>
- U.S. Federal Trade Commission reports - <https://www.ftc.gov/policy/reports>
- Reputable media sources (e.g., BBC, The Guardian, Reuters) [BBC](#)

(f) Analysis Using Sri Lanka Personal Data Protection Act No. 9 of 2022 (PDPA)

If Equifax had operated as a company in Sri Lanka, several provisions of the Personal Data Protection Act No. 9 of 2022 (PDPA) would apply.

➤ [ICTA of Sri Lanka](#)

Applicable Sections of the Act

1. Section 9 – Data Controller Responsibilities

- Requires organizations to implement appropriate technical and organizational security measures.
- Equifax failed to patch a known vulnerability, violating this duty.

2. Section 10 – Data Security Safeguards

- Requires protection against:
 - Unauthorized access
 - Loss or damage of personal data
- The breach clearly demonstrates failure to maintain adequate safeguards.

3. Section 19 – Data Breach Notification

- Requires data controllers to:
 - Notify the Data Protection Authority
 - Inform affected individuals
 - Provide details of the breach and mitigation steps

Equifax delayed public disclosure, which would violate this section.

Possible Penalties

Under the PDPA, penalties could include:

- Administrative fines
- Enforcement orders
- Suspension of data processing operations
- Possible civil liability and compensation to affected individuals

Serious violations can lead to large monetary penalties depending on severity and negligence.

Notification Requirements

Equifax would be required to:

1. Notify the regulatory authority immediately after detecting the breach.
2. Inform affected customers without undue delay.
3. Provide:
 - Nature of the breach
 - Categories of data affected
 - Steps taken to reduce harm
 - Contact information for assistance

(g) Ethical Questions After a Data Breach

The four typical ethical questions raised after breaches are:

1. Who is responsible?
2. Should the breach be disclosed immediately?
3. How should affected individuals be supported?
4. What actions should be taken to prevent future breaches?

(h) (i) Perspective of an IT Professional Who Discovered the Breach

Responsibilities

- Must report the vulnerability immediately to management.
- Should follow ethical obligations and professional integrity.

Views on Disclosure

- Likely supports early disclosure to protect users.

Customer Support

- Believes technical fixes and monitoring tools should be implemented.

Future Prevention

- Would recommend stronger security testing, patch management, and monitoring systems.

(i) (ii) Perspective of the Company CEO

Responsibilities

- Accountable for company reputation, legal compliance, and financial stability.

Views on Disclosure

- Might delay disclosure to verify facts and reduce reputational damage.

Customer Support

- Focuses on compensation programs and public relations management.

Future Prevention

- Invests in cybersecurity infrastructure and policy improvements.

(j) (iii) Perspective of an Affected Customer

Responsibilities

- Expects company accountability and transparency.

Views on Disclosure

- Strongly believes disclosure should be immediate.

Customer Support

- Wants identity protection services and financial compensation.

Future Prevention

- Expects companies to prioritize customer data security.

Conflicts Between Perspectives

Stakeholder	Main Concern	Conflict
IT Professional	Ethical responsibility and transparency	May clash with management decisions
CEO	Reputation and financial impact	May delay disclosure
Customer	Privacy and personal safety	Wants immediate action and accountability

Question 3: Conflicts of Interest

(k) Definition of Conflict of Interest

Definition (Own Words)

A conflict of interest occurs when a person's personal relationships, financial interests, or external commitments influence or interfere with their professional decisions, preventing them from acting fairly and ethically.

According to professional ethics concepts, a conflict arises when personal benefit influences professional judgment

Types of Conflicts of Interest

1. Actual Conflict of Interest

An actual conflict occurs when personal interest directly affects professional responsibilities.

Example (IT Context)

A system administrator awards a software maintenance contract to a company owned by their spouse without fair evaluation.

2. Potential Conflict of Interest

A potential conflict exists when a situation could influence decisions in the future.

Example (IT Context)

An IT student is developing a cybersecurity project while working part-time at a company that sells cybersecurity tools which they may later recommend.

3. Perceived Conflict of Interest

A perceived conflict occurs when others believe bias exists even if no unethical behavior actually occurs.

Example (IT Context)

A lecturer assigns a student's relative as the project client. Even if grading is fair, other students may assume favoritism.

(l) Conflict of Interest Decision Matrix for IT Students

Scenario	Classification	Justification
Working on a group project where your best friend is in the group	Acceptable	Friendship does not automatically cause bias if responsibilities are shared fairly.
Being offered a part-time job at a company where your family member works	Requires Disclosure	There could be influence or favoritism. Transparency maintains fairness.
Receiving gifts from a software vendor for a university project	Should Be Avoided	Gifts may influence recommendations and damage professional integrity.
Using university resources for personal freelance work	Should Be Avoided	University resources are meant for academic use and using them for profit violates institutional ethics.
Recommending a friend's startup in final year project	Requires Disclosure	The recommendation may be valid but must be disclosed to avoid bias concerns.
Having romantic relationships within project teams	Requires Disclosure	Personal relationships may influence teamwork, grading fairness, or leadership decisions.

(m) Real-World Case of Conflict of Interest in IT

Case: Yahoo Board and Alibaba Investments

Conflict:

- Yahoo's board members and executives were involved in approving Alibaba stock transactions while holding personal stock options and incentives that would benefit from Alibaba's growth.
- This created an **actual conflict of interest**, as decisions favoring Alibaba indirectly benefited executives' personal wealth.

How It Was Discovered:

- Investigative reports and shareholder lawsuits revealed that executives did not fully disclose their financial incentives linked to Alibaba's stock performance.

Consequences:

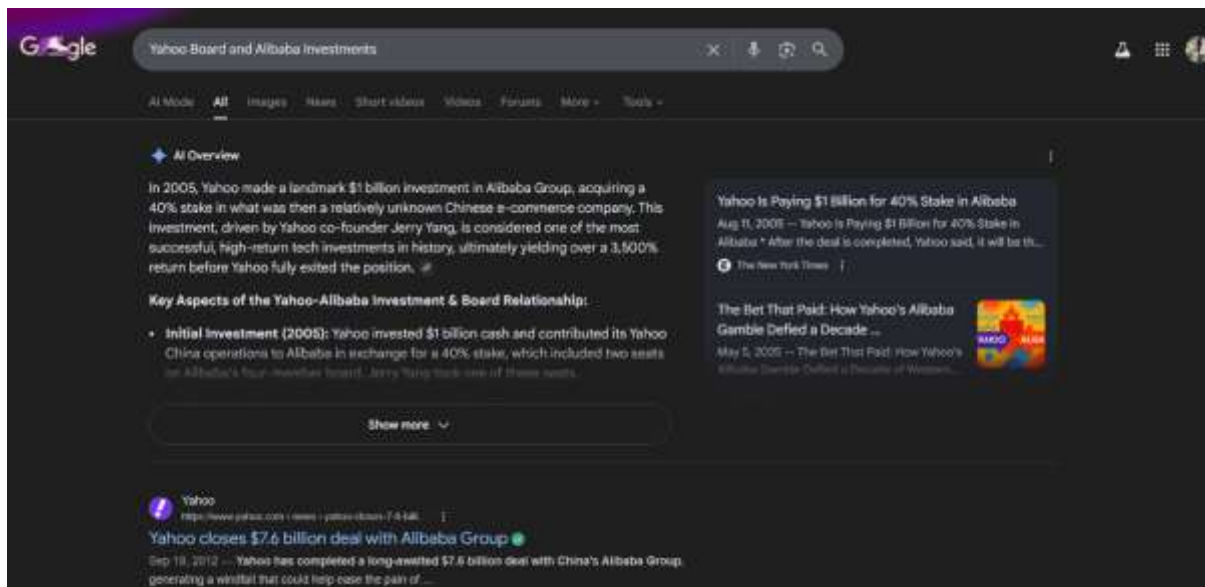
- Lawsuits and settlements were filed against Yahoo and its executives.
- Damage to reputation and investor trust.
- Some board members had to resign or were held accountable in shareholder settlements.

Lessons for IT Professionals:

1. Always disclose personal financial or relational interests that could influence professional decisions.
2. Implement independent review processes to avoid bias in strategic decisions.
3. Transparency protects both ethical integrity and organizational reputation.

Citation Example:

- Smith, J. (2013). *Yahoo and Alibaba: Conflicts of Interest in Tech Investments*. Harvard Business Review.



➡ [yahoo](https://www.yahoo.com)

Question 4 – Employee Rights in Sri Lanka

(n) Sri Lankan Legislation Relevant to IT Workers

1. Shop and Office Employees Act

Key Employee Protections

- Limits working hours.
- Requires overtime payments.
- Provides leave entitlements.

Penalties for Violations

- Employers may face fines and legal prosecution.

Important Section

- Section 3: Limits working hours (normally 45 hours per week).

2. Industrial Disputes Act

Key Employee Protections

- Provides legal framework to resolve workplace disputes.
- Allows employees to seek arbitration or labor tribunal assistance.

Penalties

- Employers violating tribunal orders may face legal penalties.

Important Section

- Section 31B: Establishes labor tribunals for employee dispute resolution.

3. Termination of Employment of Workmen Act

Key Employee Protections

- Employers must obtain approval before terminating employees.
- Requires notice or compensation.

Penalties

- Illegal termination can lead to compensation orders and reinstatement.

Important Section

- Section 2: Requires employer permission from Labour Commissioner before termination.

(o) Know Your Rights – Infographic Content (Diagram Guide)



Know Your Rights – IT Workers in Sri Lanka

Minimum Salary Protection

- Salary must follow employment agreements and labour laws.

Working Hours

- Maximum 45 hours per week.
- Overtime must be paid.

Leave Entitlements

- Annual leave
- Casual leave
- Sick leave

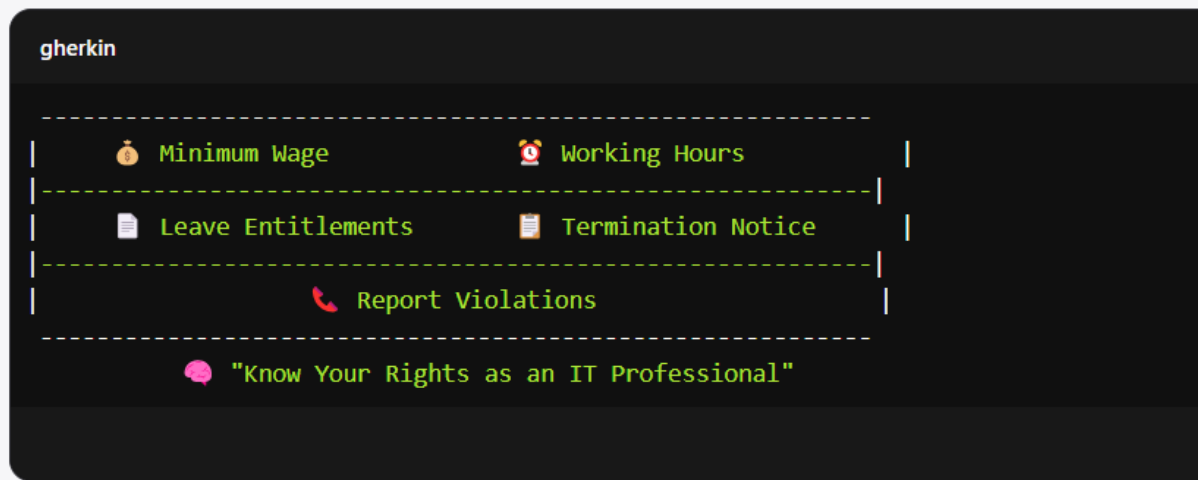
Termination Rights

- Employers must provide notice or compensation.
- Labour Commissioner approval required.

Where to Report Violations

- Department of Labour Sri Lanka
- Labour Tribunal
- Trade Unions

✓ Example Layout Sketch (Textual Representation)



Part B : Case Study Analysis

Section 1: Ethical Analysis

(p) Ethical Issues Identified

Respect for Authority

1. Pressure from management to approve unsafe deployment.

Confidentiality

2. Risk of customer banking data exposure.

Conflict of Interest

3. Performance review influencing decision making.
4. Financial contract pressure affecting ethical judgment.

Professional Responsibility

5. Duty to protect user data.

6. Responsibility to report vulnerability to bank security team.

Employee Rights

7. Excessive 60-hour work weeks.
8. Team members' concerns being ignored.

(q) Stakeholder Ethical Analysis

Stakeholder	Primary Interest	Ethical Responsibility	Conflict
Nimesh	Deliver safe product	Protect users and ensure quality	Pressure from management
Kasun (PM)	Meet deadlines	Balance delivery with safety	Financial penalties vs security
Hiruni (Dev Lead)	Protect development timeline	Ensure secure code	Downplaying risk
Dilshan (CEO)	Protect revenue and reputation	Ensure legal compliance	Profit vs user safety
The Bank	Deliver reliable service	Protect customer accounts	Launch pressure
Customers	Secure banking	Expect safe system	Trust vs risk
QE Team	Ensure quality	Report security risks	Fear of retaliation

Section 2: Legal and Regulatory Analysis

(r) Sri Lanka Personal Data Protection Act No. 9 of 2022

Data Breach Notification

- Requires organizations to notify authority and affected individuals after discovering a breach.

Security Failure Penalties

- Includes financial penalties and operational restrictions.

Controller vs Processor Responsibilities

- Software company acts as **processor**.
- Bank acts as **data controller**.
- Both must protect data.

Rights of Data Subjects

- Right to data protection.
- Right to compensation for damages.

(s) Other Relevant Sri Lankan Laws

Computer Crimes Act No. 24 of 2007

- Criminalizes unauthorized system access and data theft.

Banking Regulations (Central Bank of Sri Lanka)

- Requires strong cybersecurity and customer data protection.

(t) Comparison with the Equifax Breach

Similarities

1. Security vulnerability existed before discovery.
2. Customer financial data risk.
3. Management pressure influenced decisions.

Differences

1. Equifax breach already occurred; this scenario is pre-deployment.
2. Equifax involved credit reporting; case involves mobile banking.
3. Equifax delayed disclosure; here disclosure is still possible.

Lessons from Equifax

- Patch vulnerabilities immediately.
- Disclose risks quickly.
- Prioritize customer safety over business pressure.

Section 4 – Alternative Strategies

Strategy A: Deploy Now

Actions

- Deploy system and monitor closely.

Risk Mitigation

- Increase monitoring.
- Provide emergency patch plan.

Documentation

- Record risk acceptance approval.

Ethical & Legal Implications

- High legal risk.
- Possible violation of data protection laws.

Strategy B: Refuse to Deploy

Communication

- Provide written security risk report.

Escalation

- Inform CEO and bank security team.

Self Protection

- Maintain written documentation.

Consequences

- Project delay and possible management conflict.

Strategy C: Negotiate Middle Ground

Proposed Compromise

- Delay full deployment.
- Release limited features excluding fund transfer.

Conditions

- Bank informed about risks.
- Accelerated security patch timeline.

Stakeholder Communication

- Provide risk transparency to all parties.

Risks

- Moderate reputational and financial risk.

Section 5 – Recommendation

Recommended Strategy: Strategy C (Middle Ground)

Justification

Most Ethical Choice

- Protects customer data while reducing business damage.

Balances Interests

- Supports company, bank, and customers.

Legal Compliance

- Aligns with data protection laws.

Professional Values

- Demonstrates responsibility, integrity, and transparency.

Conclusion

This report highlights the critical importance of ethical decision-making, professional responsibility, and legal compliance in the IT sector. Through the analysis of real-world cases, such as the Equifax data breach, the Therac-25 incidents, and Snowden's whistleblowing, it is evident that decisions made by IT professionals can have far-reaching consequences for organizations, customers, and society.

In the case study of TechSolutions Lanka, the Deployment Dilemma demonstrates how pressure from management, conflicting interests, and tight deadlines can challenge ethical judgment. By applying ethical frameworks, understanding conflicts of interest, and considering Sri Lankan legal obligations—including the Personal Data Protection Act No. 9 of 2022—IT professionals can make informed choices that prioritize security, data privacy, and public trust.

The analysis emphasizes that respect for authority must be balanced with critical thinking, confidentiality and data protection are non-negotiable responsibilities, and conflicts of interest require transparency and disclosure. Moreover, employee rights and professional ethics cannot be overlooked, even under business pressure.

Ultimately, this report demonstrates that IT professionals must act proactively, ethically, and legally, ensuring that their decisions protect both organizational integrity and the rights of stakeholders. Adhering to these principles strengthens not only customer trust and organizational reputation but also the long-term sustainability of IT projects in Sri Lanka and globally.